

CONFIDENTIAL
L

Penetration Test Report

Acme Corp Q2 Greybox Assessment

Prepared for Acme Corporation

Document version 1.408
Report date 2026-04-19
Classification
CONFIDENTIAL
Methodology PTES •
OWASP WSTG v4.2 •
OWASP API Top 10 (2023) •
NIST SP 800-115
Engagement window
2026-04-19 !' 2026-04-19
Authoring firm
SentinelScan Greybox Team

Page 3 - Classification: CONFIDENTIAL - Do not distribute

1. Document Control & Revision History

This report is the property of Acme Corporation and is classified as CONFIDENTIAL. Distribution is restricted to authorized recipients identified in the rules of engagement. Any redistribution requires prior written approval.

Revision history

Version	Date	Author	Notes
1.408	2026-04-19	SentinelScan	Initial release

CONFIDENTIAL

SentinelScan executed a greybox penetration test against Acme Corporation's in-scope assets. Across 21 confirmed findings, we identified 0 critical, 0 high, 14 medium, and 7 low severity issues. The most material risks relate to Information Disclosure, Security Headers, Transport Security.

The risk posture chart below summarizes the distribution of confirmed findings by severity band. Critical and High items must be remediated within the timelines defined by the customer's vulnerability management policy (typically 7 and 30 days respectively).



Key recommendations

- Define a CSP that restricts script source to default-src 'self'; script-src 'self'; object-src 'self';
- Set `Referrer-Policy: strict-origin-when-cross-origin`
- Suppress or sanitize the `server` header
- Send `X-Frame-Options: DENY` (or `SAMEORIGIN` or `none` directive).
- Configure the web server to send `Strict-Transport-Security` over HTTPS responses.

3. Scope & Rules of Engagement

Page 5 • Classification: CONFIDENTIAL • Do not distribute

Engagement	Acme Corp Q2 Greybox Assessment
Client	Acme Corporation
Classification	CONFIDENTIAL
Web targets	https://example.com
API base URL	https://example.com/api
Rules of engagement Greybox web/API engagement. Out-of-scope: production payment endpoints. Test window Findings emailed to security@acme.example within 24h of confirmation.	

Testing followed a hybrid greybox approach combining authenticated active scanning, passive analysis of provided artefacts (source code, OpenAPI specifications, infrastructure-as-code), and manual exploitation of high-impact findings. Coverage maps to the following authoritative methodologies:

- PTES (Penetration Testing Execution Standard) — phases: pre-engagement, intelligence gathering, threat modeling, vulnerability analysis, exploitation, post-exploitation (identification only), reporting.
- OWASP Web Security Testing Guide v4.2 — 100+ test cases across information gathering, configuration, authentication, session management, authorization, input validation, error handling, cryptography, business logic, client-side and API testing.
- OWASP API Security Top 10 (2023) — BOLA, broken authentication, BFLA, mass assignment, security misconfiguration, etc.
- OWASP ASVS L1–L3 — verification controls applied selectively to in-scope components.
- NIST SP 800-115 — technical assessment guide for planning, executing and reporting.
- CIS Benchmarks — for cloud and infrastructure baseline comparison.
- MITRE ATT&CK — each finding is mapped to a relevant adversary technique where applicable.

5. Risk Rating Methodology (CVSS v3.1)

Page 7, Classification: CONFIDENTIAL, Do not distribute

Findings are scored using the Common Vulnerability Scoring System v3.1 base metric group. Each finding lists a CVSS vector composed of attack vector (AV), attack complexity (AC), privileges required (PR), user interaction (UI), scope (S), and the confidentiality (C) / integrity (I) / availability (A) impact metrics. Severity bands follow the FIRST mapping:

Severity	CVSS Range	Customer SLA
Critical	9.0 – 10.0	Patch within 7 days
High	7.0 – 8.9	Patch within 30 days
Medium	4.0 – 6.9	Patch within 60 days
Low	0.1 – 3.9	Patch in next quarterly cycle
None	0.0	Informational

#	Severity	CVSS	Title	Asset
1	Medium	6.1	Missing Content-Security-Policy header	https://example.com
2	Medium	6.1	Missing Content-Security-Policy header	https://example.com
3	Medium	5.3	Missing or weak Referrer-Policy header	https://example.com
4	Medium	5.3	Server fingerprinting via `server` header	https://example.com
5	Medium	5.3	Missing or weak Referrer-Policy header	https://example.com
6	Medium	5.3	Server fingerprinting via `server` header	https://example.com
7	Medium	5.3	Missing or weak Referrer-Policy header	https://example.com
8	Medium	5.3	Server fingerprinting via `server` header	https://example.com
9	Medium	4.3	Missing clickjacking protection (X-Frame-Options / frame-...	https://example.com
10	Medium	4.3	Missing clickjacking protection (X-Frame-Options / frame-...	https://example.com
11	Medium	4.3	Missing clickjacking protection (X-Frame-Options / frame-...	https://example.com
12	Medium	4.2	Missing HTTP Strict Transport Security (HSTS) header	https://example.com
13	Medium	4.2	Missing HTTP Strict Transport Security (HSTS) header	https://example.com
14	Medium	4.2	Missing HTTP Strict Transport Security (HSTS) header	https://example.com
15	Low	3.1	Missing X-Content-Type-Options: nosniff header	https://example.com
16	Low	3.1	Missing Permissions-Policy header	https://example.com
17	Low	3.1	Missing X-Content-Type-Options: nosniff header	https://example.com
18	Low	3.1	Missing Permissions-Policy header	https://example.com
19	Low	3.1	Missing Content-Security-Policy header	https://example.com
20	Low	3.1	Missing X-Content-Type-Options: nosniff header	https://example.com
21	Low	3.1	Missing Permissions-Policy header	https://example.com

F-001 Missing Content-Security-Policy header

MEDIUM

6.1

CVSS v3.1

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

Affected asset	https://example.com
Module	headers
Category	Security Headers
CWE	CWE-693
OWASP	A05:2021 Security Misconfiguration
MITRE ATT&CK	T1190
Likelihood	Medium

Description

No CSP is enforced. Content-Security-Policy is a key defense against XSS and content injection.

Technical details

Inspected response headers from `GET https://example.com`. Header `content-security-policy`

Proof of Concept

```
$ curl -sI https://example.com
# (no `content-security-policy` header in response)
```

Impact

Reduces browser-side defenses against common web attacks. May allow attackers to bypass mitigations layered on top of application-level controls.

Recommendation

Short term — Define a CSP that restricts script sources to trusted origins and disallows inline scripts: `Content-Security-Policy: default-src 'self'; script-src 'self'; object-src 'none'`.

Long term — Define a CSP that restricts script sources to trusted origins and disallows inline scripts: `Content-Security-Policy: default-src 'self'; script-src 'self'; object-src 'none'`. Verify the header is present on every successful and error response, including API responses.

References

- <https://owasp.org/www-project-secure-headers/>
- <https://cheatsheetseries.owasp.org/cheatsheets/HTTP-Headers-Cheat-Sheet.html>

MEDIUM

6.1

CVSS v3.1

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

Affected asset	https://example.com
Module	headers
Category	Security Headers
CWE	CWE-693
OWASP	A05:2021 Security Misconfiguration
MITRE ATT&CK	T1190
Likelihood	Medium

Description

No CSP is enforced. Content-Security-Policy is a key defense against XSS and content injection.

Technical details

Inspected response headers from `GET https://example.com`. Header `content-security-policy`

Proof of Concept

```
$ curl -sI https://example.com
# (no `content-security-policy` header in response)
```

Impact

Reduces browser-side defenses against common web attacks. May allow attackers to bypass mitigations layered on top of application-level controls.

Recommendation

Short term — Define a CSP that restricts script sources to trusted origins and disallows inline scripts: `Content-Security-Policy: default-src 'self'; script-src 'self'; object-src 'none'`.

Long term — Define a CSP that restricts script sources to trusted origins and disallows inline scripts: `Content-Security-Policy: default-src 'self'; script-src 'self'; object-src 'none'`. Verify the header is present on every successful and error response, including API responses.

References

<https://owasp.org/www-project-secure-headers/>

<https://cheatsheetseries.owasp.org/cheatsheets/HTTP-Headers-Cheat-Sheet.html>

F-003 Missing or weak Referrer-Policy header

Page 11 • Classification: CONFIDENTIAL • Do not distribute

MEDIUM

5.3

CVSS v3.1

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Affected asset	https://example.com
Module	headers
Category	Information Disclosure
CWE	CWE-200
OWASP	A05:2021 Security Misconfiguration
MITRE ATT&CK	T1190
Likelihood	Medium

Description

Without a Referrer-Policy, sensitive URL parameters may leak to third parties via the Referer header.

Technical details

Inspected response headers from `GET https://example.com`. Header `referrer-policy` is missing.

Proof of Concept

```
$ curl -sI https://example.com
# (no `referrer-policy` header in response)
```

Impact

Reduces browser-side defenses against common web attacks. May allow attackers to bypass mitigations layered on top of application-level controls.

Recommendation

Short term — Set `Referrer-Policy: strict-origin-when-cross-origin` (or stricter) on all responses.

Long term — Set `Referrer-Policy: strict-origin-when-cross-origin` (or stricter) on all responses. Verify the header is present on every successful and error response, including API responses.

References

<https://owasp.org/www-project-secure-headers/>

<https://cheatsheetseries.owasp.org/cheatsheets/HTTP-Headers-Cheat-Sheet.html>

MEDIUM

5.3

CVSS v3.1

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Affected asset	https://example.com
Module	headers
Category	Information Disclosure
CWE	CWE-200
OWASP	A05:2021 Security Misconfiguration
MITRE ATT&CK	T1592.004
Likelihood	Medium

Description

The server discloses technology and version information via the `server` header (`cloudflare`).map exploits to known CVEs.

Technical details

Header `server: cloudflare` returned by the server reveals stack details.

Proof of Concept

```
$ curl -sI https://example.com | grep -i server
```

Impact

Enables targeted exploitation by narrowing CVE search space.

Recommendation

Short term — Suppress or sanitize the `server` header at the reverse-proxy or application layer.
Long term — Remove the header in all environments, or replace it with a static, non-versioned value. Consider failing CI if these headers reappear.

References

https://owasp.org/www-community/attacks/Server-Side_Request_Forgery

F-005 Missing or weak Referrer-Policy header

Page 12 • Classification: CONFIDENTIAL • Do not distribute

MEDIUM

5.3

CVSS v3.1

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Affected asset	https://example.com
Module	headers
Category	Information Disclosure
CWE	CWE-200
OWASP	A05:2021 Security Misconfiguration
MITRE ATT&CK	T1190
Likelihood	Medium

Description

Without a Referrer-Policy, sensitive URL parameters may leak to third parties via the Referer header.

Technical details

Inspected response headers from `GET https://example.com`. Header `referrer-policy` is missing.

Proof of Concept

```
$ curl -sI https://example.com
# (no `referrer-policy` header in response)
```

Impact

Reduces browser-side defenses against common web attacks. May allow attackers to bypass mitigations layered on top of application-level controls.

Recommendation

Short term — Set `Referrer-Policy: strict-origin-when-cross-origin` (or stricter) on all responses.

Long term — Set `Referrer-Policy: strict-origin-when-cross-origin` (or stricter) on all responses. Verify the header is present on every successful and error response, including API responses.

References

<https://owasp.org/www-project-secure-headers/>

<https://cheatsheetseries.owasp.org/cheatsheets/HTTP-Headers-Cheat-Sheet.html>

MEDIUM

5.3

CVSS v3.1

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Affected asset	https://example.com
Module	headers
Category	Information Disclosure
CWE	CWE-200
OWASP	A05:2021 Security Misconfiguration
MITRE ATT&CK	T1592.004
Likelihood	Medium

Description

The server discloses technology and version information via the `server` header (`cloudflare`).map exploits to known CVEs.

Technical details

Header `server: cloudflare` returned by the server reveals stack details.

Proof of Concept

```
$ curl -sI https://example.com | grep -i server
```

Impact

Enables targeted exploitation by narrowing CVE search space.

Recommendation

Short term — Suppress or sanitize the `server` header at the reverse-proxy or application layer.
Long term — Remove the header in all environments, or replace it with a static, non-versioned value. Consider failing CI if these headers reappear.

References

https://owasp.org/www-community/attacks/Server-Side_Request_Forgery

F-007 Missing or weak Referrer-Policy header

Page 15 • Classification: CONFIDENTIAL • Do not distribute

MEDIUM

5.3

CVSS v3.1

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Affected asset	https://example.com
Module	headers
Category	Information Disclosure
CWE	CWE-200
OWASP	A05:2021 Security Misconfiguration
MITRE ATT&CK	T1190
Likelihood	Medium

Description

Without a Referrer-Policy, sensitive URL parameters may leak to third parties via the Referer header.

Technical details

Inspected response headers from `GET https://example.com`. Header `referrer-policy` is missing.

Proof of Concept

```
$ curl -sI https://example.com
# (no `referrer-policy` header in response)
```

Impact

Reduces browser-side defenses against common web attacks. May allow attackers to bypass mitigations layered on top of application-level controls.

Recommendation

Short term — Set `Referrer-Policy: strict-origin-when-cross-origin` (or stricter) on all responses.

Long term — Set `Referrer-Policy: strict-origin-when-cross-origin` (or stricter) on all responses. Verify the header is present on every successful and error response, including API responses.

References

<https://owasp.org/www-project-secure-headers/>

<https://cheatsheetseries.owasp.org/cheatsheets/HTTP-Headers-Cheat-Sheet.html>

MEDIUM

5.3

CVSS v3.1

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Affected asset	https://example.com
Module	headers
Category	Information Disclosure
CWE	CWE-200
OWASP	A05:2021 Security Misconfiguration
MITRE ATT&CK	T1592.004
Likelihood	Medium

Description

The server discloses technology and version information via the `server` header (`cloudflare`).map exploits to known CVEs.

Technical details

Header `server: cloudflare` returned by the server reveals stack details.

Proof of Concept

```
$ curl -sI https://example.com | grep -i server
```

Impact

Enables targeted exploitation by narrowing CVE search space.

Recommendation

Short term — Suppress or sanitize the `server` header at the reverse-proxy or application layer.
Long term — Remove the header in all environments, or replace it with a static, non-versioned value. Consider failing CI if these headers reappear.

References

https://owasp.org/www-community/attacks/Server-Side_Request_Forgery

F-009 Missing clickjacking protection (X-Frame-Options / frame-ancestors)

MEDIUM

4.3

CVSS v3.1

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:L/A:N

Affected asset	https://example.com
Module	headers
Category	Security Headers
CWE	CWE-1021
OWASP	A05:2021 Security Misconfiguration
MITRE ATT&CK	T1190
Likelihood	Medium

Description

The site is not protected from being embedded in a frame, enabling clickjacking attacks.

Technical details

Inspected response headers from `GET https://example.com`. Header `x-frame-options` is missing.

Proof of Concept

```
$ curl -sI https://example.com
# (no `x-frame-options` header in response)
```

Impact

Reduces browser-side defenses against common web attacks. May allow attackers to bypass mitigations layered on top of application-level controls.

Recommendation

Short term — Send `X-Frame-Options: DENY` (or `SAMEORIGIN`) and the equivalent `Content-Security-Policy: frame-ancestors 'none'` directive.

Long term — Send `X-Frame-Options: DENY` (or `SAMEORIGIN`) and the equivalent `Content-Security-Policy: frame-ancestors 'none'` directive. Verify the header is present on every successful and error response, including API responses.

References

<https://owasp.org/www-project-secure-headers/>

<https://cheatsheetseries.owasp.org/cheatsheets/HTTP-Headers-Cheat-Sheet.html>

F-010 Missing clickjacking protection (X-Frame-Options / frame-ancestors)

MEDIUM

4.3

CVSS v3.1

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:L/A:N

Affected asset	https://example.com
Module	headers
Category	Security Headers
CWE	CWE-1021
OWASP	A05:2021 Security Misconfiguration
MITRE ATT&CK	T1190
Likelihood	Medium

Description

The site is not protected from being embedded in a frame, enabling clickjacking attacks.

Technical details

Inspected response headers from `GET https://example.com`. Header `x-frame-options` is missing.

Proof of Concept

```
$ curl -sI https://example.com
# (no `x-frame-options` header in response)
```

Impact

Reduces browser-side defenses against common web attacks. May allow attackers to bypass mitigations layered on top of application-level controls.

Recommendation

Short term — Send `X-Frame-Options: DENY` (or `SAMEORIGIN`) and the equivalent `Content-Security-Policy: frame-ancestors 'none'` directive.

Long term — Send `X-Frame-Options: DENY` (or `SAMEORIGIN`) and the equivalent `Content-Security-Policy: frame-ancestors 'none'` directive. Verify the header is present on every successful and error response, including API responses.

References

<https://owasp.org/www-project-secure-headers/>

<https://cheatsheetseries.owasp.org/cheatsheets/HTTP-Headers-Cheat-Sheet.html>

F-011 Missing clickjacking protection (X-Frame-Options / frame-ancestors)

MEDIUM

4.3

CVSS v3.1

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:L/A:N

Affected asset	https://example.com
Module	headers
Category	Security Headers
CWE	CWE-1021
OWASP	A05:2021 Security Misconfiguration
MITRE ATT&CK	T1190
Likelihood	Medium

Description

The site is not protected from being embedded in a frame, enabling clickjacking attacks.

Technical details

Inspected response headers from `GET https://example.com`. Header `x-frame-options` is missing.

Proof of Concept

```
$ curl -sI https://example.com
# (no `x-frame-options` header in response)
```

Impact

Reduces browser-side defenses against common web attacks. May allow attackers to bypass mitigations layered on top of application-level controls.

Recommendation

Short term — Send `X-Frame-Options: DENY` (or `SAMEORIGIN`) and the equivalent `Content-Security-Policy: frame-ancestors 'none'` directive.

Long term — Send `X-Frame-Options: DENY` (or `SAMEORIGIN`) and the equivalent `Content-Security-Policy: frame-ancestors 'none'` directive. Verify the header is present on every successful and error response, including API responses.

References

<https://owasp.org/www-project-secure-headers/>

<https://cheatsheetseries.owasp.org/cheatsheets/HTTP-Headers-Cheat-Sheet.html>

F-012 Missing HTTP Strict Transport Security (HSTS) header

MEDIUM

4.2

CVSS v3.1

CVSS Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:L/A:N

Affected asset	https://example.com
Module	headers
Category	Transport Security
CWE	CWE-319
OWASP	A05:2021 Security Misconfiguration
MITRE ATT&CK	T1190
Likelihood	Medium

Description

The server does not return the Strict-Transport-Security response header. Without HSTS, the connection is downgraded to plain HTTP, enabling SSL stripping attacks.

Technical details

Inspected response headers from `GET https://example.com`. Header `strict-transport-security`

Proof of Concept

```
$ curl -sI https://example.com
# (no `strict-transport-security` header in response)
```

Impact

Reduces browser-side defenses against common web attacks. May allow attackers to bypass mitigations layered on top of application-level controls.

Recommendation

Short term — Configure the web server to send `Strict-Transport-Security: max-age=63072000; includeSubDomains; preload` over HTTPS responses.

Long term — Configure the web server to send `Strict-Transport-Security: max-age=63072000; includeSubDomains; preload` over HTTPS responses. Verify the header is present on every successful and error response, including API responses.

References

<https://owasp.org/www-project-secure-headers/>

https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Headers_Cheat_Sheet.html

F-013 Missing HTTP Strict Transport Security (HSTS) header

MEDIUM

4.2

CVSS v3.1

CVSS Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:L/A:N

Affected asset	https://example.com
Module	headers
Category	Transport Security
CWE	CWE-319
OWASP	A05:2021 Security Misconfiguration
MITRE ATT&CK	T1190
Likelihood	Medium

Description

The server does not return the Strict-Transport-Security response header. Without HSTS, the connection is downgraded to plain HTTP, enabling SSL stripping attacks.

Technical details

Inspected response headers from `GET https://example.com`. Header `strict-transport-security`

Proof of Concept

```
$ curl -sI https://example.com
# (no `strict-transport-security` header in response)
```

Impact

Reduces browser-side defenses against common web attacks. May allow attackers to bypass mitigations layered on top of application-level controls.

Recommendation

Short term — Configure the web server to send `Strict-Transport-Security: max-age=63072000; includeSubDomains; preload` over HTTPS responses.

Long term — Configure the web server to send `Strict-Transport-Security: max-age=63072000; includeSubDomains; preload` over HTTPS responses. Verify the header is present on every successful and error response, including API responses.

References

<https://owasp.org/www-project-secure-headers/>

<https://cheatsheetseries.owasp.org/cheatsheets/HTTP-Headers-Cheat-Sheet.html>

F-014 Missing HTTP Strict Transport Security (HSTS) header

MEDIUM

4.2

CVSS v3.1

CVSS Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:L/A:N

Affected asset	https://example.com
Module	headers
Category	Transport Security
CWE	CWE-319
OWASP	A05:2021 Security Misconfiguration
MITRE ATT&CK	T1190
Likelihood	Medium

Description

The server does not return the Strict-Transport-Security response header. Without HSTS, the connection is downgraded to plain HTTP, enabling SSL stripping attacks.

Technical details

Inspected response headers from `GET https://example.com`. Header `strict-transport-security`

Proof of Concept

```
$ curl -sI https://example.com
# (no `strict-transport-security` header in response)
```

Impact

Reduces browser-side defenses against common web attacks. May allow attackers to bypass mitigations layered on top of application-level controls.

Recommendation

Short term — Configure the web server to send `Strict-Transport-Security: max-age=63072000; includeSubDomains; preload` over HTTPS responses.

Long term — Configure the web server to send `Strict-Transport-Security: max-age=63072000; includeSubDomains; preload` over HTTPS responses. Verify the header is present on every successful and error response, including API responses.

References

<https://owasp.org/www-project-secure-headers/>

<https://cheatsheetseries.owasp.org/cheatsheets/HTTP-Headers-Cheat-Sheet.html>

F-015 Missing X-Content-Type-Options: nosniff header

Page 23 • Classification: CONFIDENTIAL • Do not distribute

LOW
3.1

CVSS v3.1

CVSS Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N

Affected asset	https://example.com
Module	headers
Category	Security Headers
CWE	CWE-693
OWASP	A05:2021 Security Misconfiguration
MITRE ATT&CK	T1190
Likelihood	Medium

Description

Without `X-Content-Type-Options: nosniff`, browsers may MIME-sniff and execute uploaded content as a different type than declared.

Technical details

Inspected response headers from `GET https://example.com`. Header `x-content-type-options`

Proof of Concept

```
$ curl -sI https://example.com
# (no `x-content-type-options` header in response)
```

Impact

Reduces browser-side defenses against common web attacks. May allow attackers to bypass mitigations layered on top of application-level controls.

Recommendation

Short term — Add `X-Content-Type-Options: nosniff` to all HTTP responses.

Long term — Add `X-Content-Type-Options: nosniff` to all HTTP responses. Verify the header is present on every successful and error response, including API responses.

References

<https://owasp.org/www-project-secure-headers/>

<https://cheatsheetseries.owasp.org/cheatsheets/HTTP-Headers-Cheat-Sheet.html>

F-016 Missing Permissions-Policy header

Page 2 of 2 • Classification: CONFIDENTIAL • Do not distribute

LOW
3.1

CVSS v3.1

CVSS Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N

Affected asset	https://example.com
Module	headers
Category	Security Headers
CWE	CWE-693
OWASP	A05:2021 Security Misconfiguration
MITRE ATT&CK	T1190
Likelihood	Medium

Description

Permissions-Policy lets the application restrict access to powerful browser features (camera, microphone, geolocation, etc.). The absence weakens the browser sandbox.

Technical details

Inspected response headers from `GET https://example.com`. Header `permissions-policy` is missing.

Proof of Concept

```
$ curl -sI https://example.com
# (no `permissions-policy` header in response)
```

Impact

Reduces browser-side defenses against common web attacks. May allow attackers to bypass mitigations layered on top of application-level controls.

Recommendation

Short term — Send a `Permissions-Policy` header explicitly disabling unused features, e.g. `geolocation=(), camera=(), microphone=()`.

Long term — Send a `Permissions-Policy` header explicitly disabling unused features, e.g. `geolocation=(), camera=(), microphone=()`. Verify the header is present on every successful and error response, including API responses.

References

<https://owasp.org/www-project-secure-headers/>

<https://cheatsheetseries.owasp.org/cheatsheets/HTTP-Headers-Cheat-Sheet.html>

F-017 Missing X-Content-Type-Options: nosniff header

Page 25 • Classification: CONFIDENTIAL • Do not distribute

LOW
3.1

CVSS v3.1

CVSS Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N

Affected asset	https://example.com
Module	headers
Category	Security Headers
CWE	CWE-693
OWASP	A05:2021 Security Misconfiguration
MITRE ATT&CK	T1190
Likelihood	Medium

Description

Without `X-Content-Type-Options: nosniff`, browsers may MIME-sniff and execute uploaded content as a different type than declared.

Technical details

Inspected response headers from `GET https://example.com`. Header `x-content-type-options`

Proof of Concept

```
$ curl -sI https://example.com
# (no `x-content-type-options` header in response)
```

Impact

Reduces browser-side defenses against common web attacks. May allow attackers to bypass mitigations layered on top of application-level controls.

Recommendation

Short term — Add `X-Content-Type-Options: nosniff` to all HTTP responses.

Long term — Add `X-Content-Type-Options: nosniff` to all HTTP responses. Verify the header is present on every successful and error response, including API responses.

References

<https://owasp.org/www-project-secure-headers/>

<https://cheatsheetseries.owasp.org/cheatsheets/HTTP-Headers-Cheat-Sheet.html>

F-018 Missing Permissions-Policy header

Page 2 of 2 • Classification: CONFIDENTIAL • Do not distribute

LOW
3.1

CVSS v3.1

CVSS Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N

Affected asset	https://example.com
Module	headers
Category	Security Headers
CWE	CWE-693
OWASP	A05:2021 Security Misconfiguration
MITRE ATT&CK	T1190
Likelihood	Medium

Description

Permissions-Policy lets the application restrict access to powerful browser features (camera, microphone, geolocation, etc.). The absence weakens the browser sandbox.

Technical details

Inspected response headers from `GET https://example.com`. Header `permissions-policy` is missing.

Proof of Concept

```
$ curl -sI https://example.com
# (no `permissions-policy` header in response)
```

Impact

Reduces browser-side defenses against common web attacks. May allow attackers to bypass mitigations layered on top of application-level controls.

Recommendation

Short term — Send a `Permissions-Policy` header explicitly disabling unused features, e.g. `geolocation=(), camera=(), microphone=()`.

Long term — Send a `Permissions-Policy` header explicitly disabling unused features, e.g. `geolocation=(), camera=(), microphone=()`. Verify the header is present on every successful and error response, including API responses.

References

<https://owasp.org/www-project-secure-headers/>
<https://cheatsheetseries.owasp.org/cheatsheets/HTTP-Headers-Cheat-Sheet.html>

LOW
3.1

CVSS v3.1

CVSS Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N

Affected asset	https://example.com
Module	headers
Category	Security Headers
CWE	CWE-693
OWASP	A05:2021 Security Misconfiguration
MITRE ATT&CK	T1190
Likelihood	Medium

Description

No CSP is enforced. Content-Security-Policy is a key defense against XSS and content injection.

Technical details

Inspected response headers from `GET https://example.com`. Header `content-security-policy`

Proof of Concept

```
$ curl -sI https://example.com
# (no `content-security-policy` header in response)
```

Impact

Reduces browser-side defenses against common web attacks. May allow attackers to bypass mitigations layered on top of application-level controls.

Recommendation

Short term — Define a CSP that restricts script sources to trusted origins and disallows inline scripts: `Content-Security-Policy: default-src 'self'; script-src 'self'; object-src 'none'`.

Long term — Define a CSP that restricts script sources to trusted origins and disallows inline scripts: `Content-Security-Policy: default-src 'self'; script-src 'self'; object-src 'none'`. Verify the header is present on every successful and error response, including API responses.

References

<https://owasp.org/www-project-secure-headers/>
<https://cheatsheetseries.owasp.org/cheatsheets/HTTP-Headers-Cheat-Sheet.html>

F-020 Missing X-Content-Type-Options: nosniff header

Page 28 • Classification: CONFIDENTIAL • Do not distribute

LOW
3.1

CVSS v3.1

CVSS Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N

Affected asset	https://example.com
Module	headers
Category	Security Headers
CWE	CWE-693
OWASP	A05:2021 Security Misconfiguration
MITRE ATT&CK	T1190
Likelihood	Medium

Description

Without `X-Content-Type-Options: nosniff`, browsers may MIME-sniff and execute uploaded content as a different type than declared.

Technical details

Inspected response headers from `GET https://example.com`. Header `x-content-type-options`

Proof of Concept

```
$ curl -sI https://example.com
# (no `x-content-type-options` header in response)
```

Impact

Reduces browser-side defenses against common web attacks. May allow attackers to bypass mitigations layered on top of application-level controls.

Recommendation

Short term — Add `X-Content-Type-Options: nosniff` to all HTTP responses.

Long term — Add `X-Content-Type-Options: nosniff` to all HTTP responses. Verify the header is present on every successful and error response, including API responses.

References

<https://owasp.org/www-project-secure-headers/>

<https://cheatsheetseries.owasp.org/cheatsheets/HTTP-Headers-Cheat-Sheet.html>

F-021 Missing Permissions-Policy header

Page 2 of 2 • Classification: CONFIDENTIAL • Do not distribute

LOW
3.1

CVSS v3.1

CVSS Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N

Affected asset	https://example.com
Module	headers
Category	Security Headers
CWE	CWE-693
OWASP	A05:2021 Security Misconfiguration
MITRE ATT&CK	T1190
Likelihood	Medium

Description

Permissions-Policy lets the application restrict access to powerful browser features (camera, microphone, geolocation, etc.). The absence weakens the browser sandbox.

Technical details

Inspected response headers from `GET https://example.com`. Header `permissions-policy` is missing.

Proof of Concept

```
$ curl -sI https://example.com
# (no `permissions-policy` header in response)
```

Impact

Reduces browser-side defenses against common web attacks. May allow attackers to bypass mitigations layered on top of application-level controls.

Recommendation

Short term — Send a `Permissions-Policy` header explicitly disabling unused features, e.g. `geolocation=(), camera=(), microphone=()`.

Long term — Send a `Permissions-Policy` header explicitly disabling unused features, e.g. `geolocation=(), camera=(), microphone=()`. Verify the header is present on every successful and error response, including API responses.

References

<https://owasp.org/www-project-secure-headers/>
<https://cheatsheetseries.owasp.org/cheatsheets/HTTP-Headers-Cheat-Sheet.html>

The roadmap below sequences remediation work by risk × effort. Items at the top should be addressed first.

Wave	Severity	Theme	Action
Wave 1	Medium	Security Headers	5 findings — Define a CSP that restricts script sources to .
Wave 2	Medium	Information Disclosure	6 findings — Set `Referrer-Policy: strict-origin-when-cross-
Wave 3	Medium	Transport Security	3 findings — Configure the web server to send `Strict-Transport-
Wave 4	Low	Security Headers	7 findings — Add `X-Content-Type-Options: nosniff` to all HTTP responses.

The following tools and engines were orchestrated by the SentinelScan platform during this engagement. The platform normalizes output from each engine into a common finding schema so that severities and remediations are consistent regardless of the producing tool.

- OWASP ZAP / Nuclei templates — web active scanning (XSS, SQLi, SSRF, IDOR).
- sslyze-style TLS probing — protocol, cipher and certificate hygiene.
- Nmap — service / version discovery for in-scope hosts.
- Trivy / Checkov — IaC and cloud configuration analysis.
- Semgrep — source-level SAST with curated ruleset.
- OSV / Trivy — software composition analysis on declared dependencies.
- Internal hybrid orchestrator — header / CORS / OpenAPI fuzzing and rate-limit probes.

BOLA Broken Object Level Authorization — a server fails to verify the caller is allowed to access the requested object identifier.

BFLA Broken Function Level Authorization — a server fails to enforce role / function restrictions on an endpoint.

CSP Content Security Policy — a browser-enforced policy restricting which sources may serve scripts, styles and other resources.

CVE Common Vulnerabilities and Exposures — public catalogue of known vulnerabilities.

CVSS Common Vulnerability Scoring System — vendor-neutral severity rating system.

CWE Common Weakness Enumeration — catalogue of software weakness types.

HSTS HTTP Strict Transport Security — header that forces browsers to use HTTPS.

MITRE ATT&CK Knowledge base of adversary tactics and techniques mapped to real-world incidents.

PoC Proof of Concept — minimal artefact

demonstrating
a
v
ul
n
er
a
bi

lit

y.

S

A

S

T

St

at

ic

A

p

pl

ic

at

**io
n
s
e
c
ur
it
y**

**T
e
st
in
g
—
s
o**

ur

c

e-

le

v

el

a

n

al

y

si

s.

s

C

A

**S
of
t
w
ar
e
C**

**o
m
p
o
si
ti
o
n**

A

n

al

y

si

s

—

d

et

e

ct

io

n

of

v

ul

n
er
a
bl
e
th
ir
d-

**p
ar
ty
p
a
c
k
a**

**g
e
s.
s
s
R
F**

CONFIDENTIAL

**S
er
v
er
-S
id
e**

**R
e
q
u
e
st
F
or**

g

er

y

—

s

er

v

er

**c
a
n
b
e
c
o
er**

**c
e
d
to

m
a
k**

e

H

T

T

P

re

q

u

**e
st
s
o
n
th
e
at**

ta

c

k

er

's

b

e

h

al

f.

CONFIDENTIAL